



آموزش رد تیم و تست نفوذ TryHackBox

دستورالعمل های مفید جستجوی گوگل: سایت ها و لینک ها

تهیه شده توسط تیم TryHackBox

Google Dork

برای درک چگونگی استفاده از موتورهای جستجو (به ویژه گوگل) برای پیدا کردن سیستم های آسیب پذیر، مدتی را به بررسی قابلیت های جستجوی پیشرفته در گوگل اختصاص خواهیم داد. با به کارگیری اصول مختلف جستجو که در آموزش های بعدی بحث خواهیم کرد و ترکیب آن ها به روش های خلاقانه، می توانیم از گوگل برای پیدا کردن سیستم های دارای نقص در محیط های تارگت خود استفاده کنیم. بیایید دستورالعمل های مرتبط با بررسی وبسایت ها و دامنه های خاص را بررسی کنیم.

مقدمه: چرا Google Dorks برای هکرها حیاتی است؟

گوگل فقط یک موتور جستجوی ساده نیست! به عنوان "پر قدرت ترین اسکنر آسیب پذیری رایگان جهان" شناخته می شود. با ترکیب هوشمندانه دستورات (Dorks)، می توانید:

- سیستم های مدیریت محتوای (CMS) قدیمی و آسیب پذیر را شناسایی کنید.
- فایل های حساس (مثل passwd، config.php، backup.zip) را کشف نمایید.
- پورتال های مدیریتی مخفی (مثل /admin، /wp-login.php) را ردیابی کنید.

site • - :این دستور به مهاجم اجازه می دهد صفحات را فقط در یک سایت یا دامنه خاص جستجو کند و جستجو را محدود و متمرکز نماید. به عنوان مثال، اگر بخواهید صفحات را فقط در دامنه sans.org برای عبارت "web app" جستجو کنید، می توانید از جستجوی site:sans.org "web app" استفاده کنید. آیا تا به حال سایتی دیده اید که قابلیت جستجوی داخلی نداشته باشد (مثل sans.org) یا دارای قابلیت جستجوی ضعیفی باشد؟ با دستور "site:" در گوگل، اکنون می توانید از گوگل برای جستجوی نتایج مرتبط با همان سایت استفاده کنید و به قدرت گوگل و دستورات و عملگرهای انعطاف پذیر جستجوی آن تکیه کنید. دستور "site:" می تواند خاص باشد، مثل site:example.university.edu، یا گسترده، مثل site:.edu که تمام سایت های با پسوند .edu را پوشش می دهد.

دستور site: یکی از قدرتمندترین ابزارهای جمع آوری اطلاعات (OSINT) برای متخصصان امنیت سایبری است. این دستور به شما امکان می دهد جستجوی خود را به یک دامنه یا زیردامنه خاص محدود کنید.

مثال عملی :

1. شناسایی زیرساخت های تارگت:

- site:target.com

- لیست تمام صفحات ایندکس شده تارگت را نمایش می دهد

• کشف زیردامنه ها:

- site:*.target.com

- تمام زیردامنه های سازمان تارگت را شناسایی می کند

• پیدا کردن محتوای حساس:



```
site:target.com "confidential"
```

تکنیک‌های پیشرفته:

1. ترکیب با عملگرهای دیگر:

- ```
site:target.com intitle:"admin"
```

```
site:target.com filetype:pdf
```

### • جستجوی در TLD های خاص:

- ```
site:.ir "ورود مدیریت"
```

```
site:.gov "classified"
```

• شناسایی فایل‌های پیکربندی:

```
site:target.com ext:env | ext:ini | ext:conf
```

تمرین عملی:

1. شناسایی سیستم‌های مدیریت محتوا:

- ```
site:target.com inurl:/wp-admin/
```

### • پیدا کردن صفحات لاگین:

- ```
site:target.com intitle:"login" | "sign in"
```

• کشف API ها:

```
site:target.com inurl:/api/v1/
```

Intitle - این دستور معیارهای جستجو را در عنوان صفحه که در نوار عنوان یا تب مرورگر نمایش داده می‌شود، جستجو می‌کند. یکی از مفیدترین انواع عنوان‌ها برای جستجو، مربوط به فهرست‌نویسی دایرکتوری در یک وب‌سایت است. در وب‌سایت‌هایی که با قابلیت فهرست‌نویسی دایرکتوری پیکربندی شده‌اند، سرور وب محتویات آن دایرکتوری را به مرورگر باز می‌گرداند، با صفحه‌ای خودکار که عنوان آن شامل متن "Index of" است. بنابراین، می‌توانیم از `intitle:index.of passwd` برای جستجوی دایرکتوری‌هایی که در آن‌ها فایلی به نام `passwd` وجود دارد، استفاده کنیم. ممکن است فایل `/etc/passwd` را پیدا کنیم. توجه داشته باشید که بسیاری از فایل‌های `passwd` در دامنه‌های جالب قابل کشف توسط جستجوهای گوگل، یا فایل‌های `/etc/passwd` تله‌ای هستند یا سایت‌هایی که ممکن است سعی در سوءاستفاده از مرورگر شما داشته باشند! بنابراین در انجام این نوع جستجو احتیاط کنید، مگر اینکه آن را با استفاده از دستور "site:" به دامنه‌های قابل اعتمادتر محدود کنید.

دستور `intitle:` یکی از قدرتمندترین ابزارهای شناسایی سیستم‌های آسیب‌پذیر در فاز جمع‌آوری اطلاعات (Reconnaissance) است. این دستور صفحاتی را پیدا می‌کند که عنوان **HTML** آنها شامل عبارت مورد نظر شما باشد.

مثال

۱. شناسایی دایرکتوری‌های باز

```
intitle:"index of" "parent directory"
```

- کاربرد: پیدا کردن فهرست‌های وب که به اشتباه در دسترس عموم قرار گرفته‌اند
- مثال عملی در تست نفوذ:

- `intitle:"index of" site:target.com`



آموزش رد تیم و تست نفوذ TryHackBox

این جستجو تمام دایرکتوری‌های باز در سازمان تارگت را نشان می‌دهد

۲. کشف فایل‌های حساس سیستم

```
intitle:"index of" passwd
```

- خطر امنیتی: ممکن است فایل `/etc/passwd` لینوکس را نمایش دهد
- مثال پیشرفته:

- `intitle:"index of" (passwd | shadow | config.php) site:gov.*`
○ جستجوی فایل‌های حیاتی در دامنه‌های دولتی

۳. شناسایی پنل‌های مدیریتی

```
intitle:"admin login"
```

- تکنیک تست نفوذ:

```
intitle:"admin" (login | panel | dashboard) site:target.com
```

- کشف تمام صفحات مدیریتی سازمان تارگت

تکنیک‌های ترکیبی

ترکیب با `site:` برای تمرکز بر تارگت

```
intitle:"webcam" site:university.*
```

- کاربرد: پیدا کردن دوربین‌های تحت وب دانشگاه‌ها

ترکیب با `inurl:` برای دقت بیشتر

```
intitle:"login" inurl:/admin/
```

- مثال: شناسایی صفحات لاگین مدیریتی

سناریوی عملی تست نفوذ شبکه

مرحله ۱: شناسایی زیرساخت

```
intitle:"Apache HTTP Server" site:company.com
```

- شناسایی سرورهای وب سازمان

مرحله ۲: کشف آسیب پذیری ها

```
intitle:"index of" /backup site:company.com
```

- پیدا کردن فایل های بکاپ حاوی اطلاعات حساس

مرحله ۳: ورود به سیستم

```
intitle:"login" "username" "password" site:company.com
```

- شناسایی صفحات احراز هویت برای تست brute-force

Inurl - این دستور به ما امکان می دهد عبارات خاصی را در URL یک سایت مشخص جستجو کنیم. این می تواند برای پیدا کردن اسکریپت های آسیب پذیر شناخته شده در سرورهای وب از جمله CGI، ASP، JSP و PHP و سایر موارد مفید باشد. به عنوان مثال، جستجوی `inurl:viewtopic.php` سایت هایی را پیدا می کند که در URL آنها `"viewtopic.php"` وجود دارد. این اسکریپت معمولاً با مجموعه ابزارهای phpBB برای پیاده سازی انجمن های گفتگوی تحت وب مرتبط است. از نظر تاریخی، نقاط ضعف متعددی در پیاده سازی های phpBB وجود داشته است، بنابراین پیدا کردن این سایت ها در صورت کشف آسیب پذیری جدید مفید خواهد بود.

دستور `inurl` یکی از قدرتمندترین ابزارهای شناسایی نقاط ضعف در شبکه است که به شما امکان می دهد URL های حاوی رشته های خاص را جستجو کنید. این تکنیک بخشی از مرحله جمع آوری اطلاعات (**Reconnaissance**) در تست نفوذ است.

مثال های عملی در تست نفوذ شبکه

۱. پیدا کردن پنل های مدیریتی

```
inurl:/admin/login.php
```



آموزش رد تیم و تست نفوذ TryHackBox

این جستجو سایت‌هایی را پیدا می‌کند که از پنل مدیریتی با نام login.php استفاده می‌کنند.

۲. شناسایی دوربین‌های تحت شبکه

```
inurl:/view/view.shtml
```

این جستجو اغلب به صفحه نمایش دوربین‌های نظارتی که به اینترنت متصل هستند منجر می‌شود.

۳. پیدا کردن سیستم‌های مدیریت محتوا (CMS)

```
inurl:/wp-admin (برای وردپرس)
```

```
inurl:/administrator (برای جوملا)
```

۴. کشف فایل‌های پیکربندی حساس

```
inurl:/config.php.bak
```

این جستجو ممکن است فایل‌های پشتیبان پیکربندی را که حاوی اطلاعات حساس هستند پیدا کند.

۵. پیدا کردن صفحات لاگین قدیمی

```
inurl:/login.asp
```

این جستجو سیستم‌های قدیمی که ممکن است آسیب‌پذیری‌های شناخته شده داشته باشند را پیدا می‌کند.

تکنیک‌های پیشرفته ترکیب با سایر عملگرها

۱. ترکیب با: site:

```
site:example.com inurl:admin
```

این جستجو تمام صفحات زیردامنه example.com که شامل کلمه admin در URL هستند را پیدا می‌کند.

۲. ترکیب با: intitle:

```
inurl:login intitle:"Login"
```

این جستجو صفحات لاگینی که هم در URL و هم در عنوان صفحه کلمه Login وجود دارد را پیدا می‌کند.

۳. ترکیب با: filetype:

```
inurl:/backup filetype:sql
```

این جستجو فایل‌های پشتیبان بانک اطلاعاتی با پسوند sql را پیدا می‌کند.



مثال عملی تست نفوذ به یک شبکه

سناریو: شما به عنوان تست نفوذگر می خواهید آسیب پذیری های احتمالی در یک سازمان را بررسی کنید.

۱. ابتدا دامنه سازمان را شناسایی می کنید (مثلا example.com)

۲. جستجوی اولیه:

```
site:example.com inurl:login
```

این جستجو تمام صفحات لاگین سازمان را نشان می دهد.

۳. بررسی سیستم های مدیریت محتوا:

```
site:example.com inurl:/wp-admin
```

اگر نتیجه داشت، نشان دهنده استفاده از وردپرس است.

۴. جستجوی فایل های حساس:

```
site:example.com inurl:/etc/passwd
```

این جستجو ممکن است فایل های حساس سیستم را نشان دهد اگر به اشتباه در دسترس باشند.

تمرین عملی

سعی کنید این جستجوها را انجام دهید و نتایج را تحلیل کنید:

```
inurl:/phpmyadmin/index.php
```

```
inurl:/cgi-bin/login.cgi
```

```
inurl:/remote/login
```

این تکنیک ها بخشی از مرحله جمع آوری اطلاعات (Information Gathering) در تست نفوذ هستند و می توانند به شناسایی نقاط ورود احتمالی کمک کنند.

دستورات جستجوی گوگل برای تست نفوذ:

1. Site :

- فقط در دامنه مشخص شده جستجو می کند
- مثال "web app" site:sans.org
- نتایجی را نمایش می دهد که عبارت "web app" در دامنه sans.org دارند

2. Intitle :

- عنوان صفحه با معیار جستجو مطابقت دارد
- مثال intitle:index.of passwd
- دایرکتوری های ایندکس شده وب را پیدا می کند که کلمه "passwd" در لیست دایرکتوری دارند (احتمالاً فایل /etc/passwd)

3. Inurl :

- URL با معیار جستجو مطابقت دارد
- مثال inurl:viewtopic.php
- اسکریپتی را پیدا می کند که در phpBB استفاده شده است (این سیستم تاریخچه ای از آسیب پذیری های مهم دارد)

جستجوی انواع فایل ها

اغلب اوقات، ما می خواهیم در گوگل به دنبال نوع خاصی از فایل ها بگردیم. بیشتر وب از صفحات html و htm تشکیل شده است، اما انواع دیگری از فایل ها وجود دارند که برای ما جالب هستند. وقتی گوگل در اینترنت جستجو می کند، سایت های جدید را پیدا کرده و صفحات آن ها را به فهرست جستجوی خود اضافه می کند، او چند صد نوع فایل مختلف را شناسایی می کند که به ما اجازه می دهد فقط آن نوع فایل ها را جستجو کنیم. برای مثال، می توانیم به دنبال فایل های pdf بگردیم. یا برای جالب تر کردن موضوع، می توانیم فایل های xls را جستجو کنیم که معمولاً با صفحات گسترده اکسل مرتبط هستند. همچنین ممکن است فایل های ppt.

را جستجو کنیم تا ارائه‌های پاورپوینت را پیدا کنیم. برخی سازمان‌ها به طور ناخواسته فایل‌های حساس .xls یا .ppt را روی وبسایت‌های خود قرار می‌دهند، که ما می‌توانیم برای پیدا کردن آن‌ها جستجو کنیم.

برای انجام چنین جستجوهایی، دو گزینه داریم. اولین گزینه این است که به دستور "filetype:" گوگل همراه با پسوند فایل مورد نظرمون تکیه کنیم. توجه داشته باشید که دستور "ext:" دقیقاً همان کار دستور "filetype:" را انجام می‌دهد؛ این دو جستجو کاملاً یکسان هستند. برای مثال، می‌توانیم فایل‌های پاورپوینت را در دامنه counterhack.net با جستجوی filetype:ppt site:counterhack.net یا site:counterhack.net ext:ppt پیدا کنیم. گزینه دوم ما این است که پسوند فایل را به عنوان یک عبارت جستجوی عمومی جستجو کنیم. گاهی اوقات گوگل در تشخیص نوع فایل دچار اشتباه می‌شود و ارتباط مناسب را برقرار نکرده و آن فایل را از نتایج filetype: حذف می‌کند. استفاده از پسوند فایل به عنوان یک عبارت جستجوی عمومی بدون دستور filetype: یا ext: معمولاً نتایج بیشتری به ما می‌دهد، چون نه تنها فایل‌هایی که آن پسوند را در نامشان دارند پیدا می‌کنیم، بلکه صفحات وبی که فقط شامل متن مرتبط با آن پسوند هستند را هم دریافت می‌کنیم. برای مثال، اگر جستجو کنیم ppt site:counterhack.net، نه تنها فایل‌های پاورپوینت را می‌یابیم، بلکه مجموعه‌ای از صفحات وب که شامل متن ppt هستند را هم دریافت می‌کنیم.

در تست نفوذ شبکه، جستجوی فایل‌های خاص روی وبسایت‌ها می‌تواند به کشف اطلاعات حساس یا نقاط ضعف کمک کند. مثلاً با جستجوی فایل‌های .xls یا .ppt، ممکن است فایل‌هایی پیدا کنید که شامل اطلاعات داخلی، رمز عبور، پیکربندی‌ها یا اسناد محرمانه باشند که به اشتباه روی وب منتشر شده‌اند.

مثلاً:

اگر با دستور

```
`site:example.com filetype:xls`
```

جستجو کنیم، ممکن است فایل‌های اکسل حاوی اطلاعات مالی، لیست کاربران، یا تنظیمات داخلی سازمان را پیدا کنیم که به طور ناخواسته روی وب منتشر شده‌اند.



یا با

`site:example.com filetype:ppt`

می‌توانیم ارائه‌های پاورپوینت را بیابیم که ممکن است شامل نقشه‌های شبکه، ساختار سازمانی، یا اطلاعات فنی مهم باشند.

همچنین جستجوی عمومی پسوند بدون دستور filetype، مثل

`site:example.com ppt`

ممکن است صفحات وبی را نشان دهد که درباره فایل‌های پاورپوینت صحبت می‌کنند یا لینک به آن‌ها دارند، که می‌تواند سرخ‌های بیشتری برای نفوذ فراهم کند.

این روش‌ها به پنتسترها کمک می‌کند تا اطلاعاتی که به صورت ناخواسته افشا شده‌اند را شناسایی کند و نقاط ضعف احتمالی را قبل از مهاجمان واقعی پیدا کند.

چند مثال واقعی برای جستجوی فایل‌ها در دامنه فرضی example.com که در تست نفوذ کاربرد دارند:

1. برای پیدا کردن فایل‌های اکسل احتمالی که ممکن است اطلاعات حساس داشته باشند:

site:example.com filetype:xls

2. برای پیدا کردن ارائه‌های پاورپوینت که ممکن است نقشه شبکه یا اطلاعات فنی را افشا کنند:

site:example.com filetype:ppt

3. اگر گوگل فایل‌ها را به درستی شناسایی نکرد، می‌توان پسوند را به صورت عبارت جستجو کرد تا نتایج بیشتری بگیریم:

site:example.com xls

4. جستجوی فایل‌های PDF که ممکن است مستندات یا گزارش‌های داخلی باشند:

site:example.com filetype:pdf

این جستجوها به پنتستر کمک می‌کند تا فایل‌های حساس یا اطلاعاتی که نباید عمومی باشند را پیدا کند و ریسک‌های امنیتی را شناسایی کند.

فهرست نقاط ضعف قابل کشف از طریق گوگل

چند سال پیش، جانی لانگ لیستی از جستجوهای مفید گوگل برای پیدا کردن سیستم‌های آسیب‌پذیر ایجاد کرد. او هر یک از این جستجوها را «گوگل دورک (Google Dork)» نامید و کل مجموعه این جستجوها به عنوان «پایگاه داده هک گوگل (Google Hacking Database | GHDB)» شناخته شد. امروز، افرادی که «اکسپلویت-دی بی (Exploit-DB)» را اداره می‌کنند، کار جانی را ادامه داده‌اند و یک لیست قابل جستجو از GHDB به‌روزشده را در آدرس URL نشان‌داده‌شده در این اسلاید، به صورت آنلاین ارائه می‌دهند. بیش از ۱۰۰۰ جستجوی مختلف در GHDB وجود دارد که می‌توانند انواع مختلفی از نقص‌های امنیتی و مسائل مرتبط را تنها با جستجوی ساده در گوگل پیدا کنند.

دسته‌بندی‌های GHDB

پایگاه داده هک گوگل به دسته‌های متعددی تقسیم شده است. تمامی این دسته‌ها در اسلاید فهرست شده‌اند، اما برخی از مهم‌ترین و جالب‌ترین موارد برای ما عبارتند از:

- **اطلاعیه‌ها و آسیب‌پذیری‌ها:** این جستجوها سیستم‌های آسیب‌پذیر را پیدا می‌کنند، معمولاً با شناسایی اسکریپت‌های CGI دارای نقص شناخته‌شده با استفاده از دستور `inurl` یا صفحاتی با نقص‌های مشخص‌شده با دستور `intitle`.
- **فایل‌های حاوی اطلاعات حساس:** این جستجوها فایل‌هایی را پیدا می‌کنند که اغلب با کش‌ها و لاگ‌ها مرتبط هستند. اگرچه مستقیماً به دنبال رمزهای عبور نمی‌گردند، اما این اطلاعات کش و لاگ می‌توانند برای یادگیری بیشتر درباره سازمان هدف مفید باشند.

- **فایل‌های حاوی رمزهای عبور**: ابزارهای متعددی فایل‌هایی تولید می‌کنند که شامل رمزهای عبور متن‌خوان یا رمزهای رمزنگاری‌شده/هش‌شده هستند. این جستجوها مواردی را شناسایی می‌کنند که چنین فایل‌هایی از طریق یک سرور وب در دسترس هستند.
- **پایه‌های نفوذ**: این جستجوها سایت‌هایی را پیدا می‌کنند که ممکن است یک مهاجم در آن‌ها جای پای پیدا کند و بعداً از آن برای به خطر انداختن سرور استفاده کند. بسیاری از این جستجوها صفحات ورود ادمین برای محیط‌های نرم‌افزاری مبتنی بر وب رایج را پیدا می‌کنند. دسته **پورتال‌های ورود** نیز مشابه است.
- **داده‌های شبکه یا آسیب‌پذیری**: این جستجوها صفحاتی را پیدا می‌کنند که حاوی لاگ‌ها و/یا اطلاعات پیکربندی درباره دستگاه‌های شبکه مانند فایروال‌ها، VPN‌ها، روترها، سیستم‌های تشخیص نفوذ و غیره هستند.
- **دستگاه‌های آنلاین**: این دسته از جستجوها به پیدا کردن دوربین‌های وب‌محور، پرینترها و انواع مختلف دستگاه‌های جانبی کمک می‌کند.
- **سرورهای آسیب‌پذیر**: این جستجوها وب سرورهایی را پیدا می‌کنند که ممکن است دارای یک آسیب‌پذیری باشند، دسته‌ای مشابه **اطلاعی‌ها و آسیب‌پذیری‌ها**.

پیدا کردن آسیب‌پذیری: چند نمونه جالب از GHDB

SQL Injection	<code>inurl:".php?id=" "You have an error in your SQL syntax"</code>
Bash History	<code>intitle:"index of" ./bash_history</code>
Login pages	<code>inurl:/login.asp "Configuration and Management"</code>
Admin SQL Files	<code>intext:admin ext:sql inurl:admin</code>

اگرچه GHDB شامل صدها جستجوی جالب در گوگل برای پیدا کردن سایت‌های آسیب‌پذیر یا داده‌های حساس است، بیایید چند مورد از آنها را بررسی کنیم تا قدرت GHDB و گوگل را درک کنیم.

اولین جستجو در این اسلاید، صفحات php را شناسایی میکند که پارامتر "id" در URL دارند و یک پیام خطای رایج SQL injection در صفحه وجود دارد. این به مهاجم اجازه میدهد تا به راحتی یک آسیب پذیری شدید در برنامه وب را شناسایی کند که ممکن است منجر به افشای داده های حساس شود.

جستجوی دوم، سایت هایی را نشان میدهد که فهرست داری (directory indexing) در آنها فعال است و یک فایل به نام "bash_history" وجود دارد. این فایل شامل لیست دستورات وارد شده توسط کاربر است و ممکن است اهداف جالبی یا حتی رمزهای عبور را در خود داشته باشد، اگر کاربر رمز را در جای اشتباهی وارد کرده باشد.

جستجوی سوم، صفحات ورود به سیستم (login) را با عبارت "Configuration and Management" در صفحه شناسایی میکند. این معمولاً با صفحات ورود مدیریتی مرتبط است.

آخرین جستجو، فایل های SQL (که معمولاً شامل کوئری های پایگاه داده هستند) را با کلمه "admin" هم در متن و هم در URL پیدا میکند. براس گفته خالق این کوئری: «با استفاده از پسوند sql و عبارتهای intext admin و inurl admin، توانستم به برخی از فایل های ادمین SQL و حتی کوئری های SQL دسترسی پیدا کنم که اطلاعات حساسی مانند شناسه ورود و رمز عبور به صورت متن واضح را افشا میکردند».

اضافه کردن `site:yourtarget.com` برای محدود کردن نتایج به سازمان تارگت شما

برخی نتایج ممکن است عمداً برای شناسایی پنتسترها قرار داده شده باشند

همیشه از محیط ایزوله (مثل VM) برای بررسی استفاده کنید